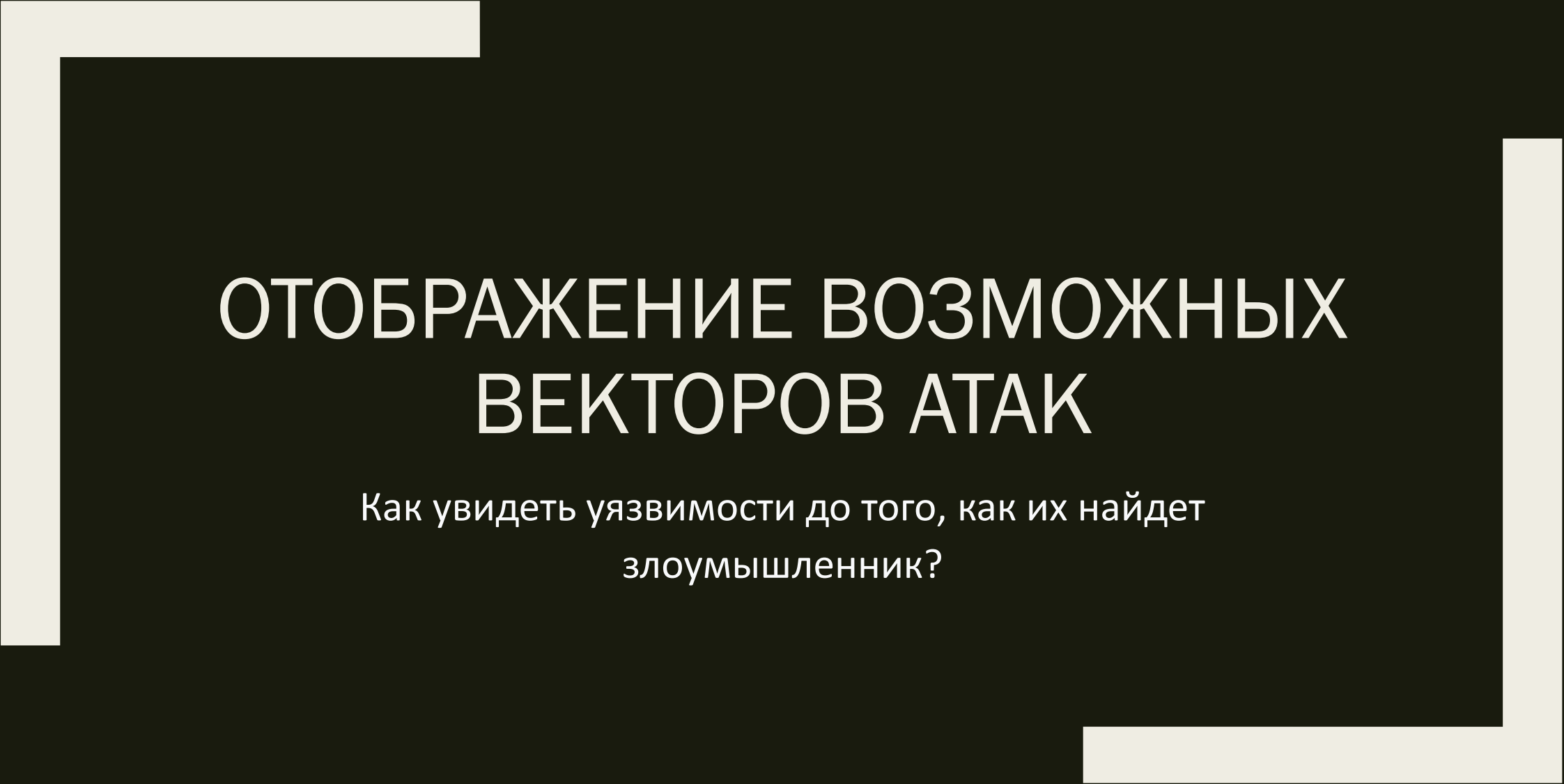




ОТОБРАЖЕНИЕ ВОЗМОЖНЫХ ВЕКТОРОВ АТАК

Как увидеть уязвимости до того, как их найдет
злоумышленник?

Откуда могут прийти угрозы?

Определение: Совокупность всех возможных точек, путей и методов, через которые злоумышленник может получить несанкционированный доступ к системе или данным.

Простая аналогия: Дом. Поверхность атаки — это все окна, двери, вентиляционные шахты, даже почтовый ящик.

Цель отображения: Сделать абстрактную угрозу наглядной, чтобы системно находить и устранять слабые места.

Основной принцип: «Вы не можете защитить то, чего не видите».

Что именно мы картируем?

Сетевая поверхность:

- Открытые порты (80/HTTP, 443/HTTPS, 22/SSH, и т.д.).
- Доменные имена, поддомены (включая забытые тестовые dev, staging).
- Сетевые службы и их версии.

Что именно мы картируем?

Поверхность приложения (наиболее обширная):

- Все входные точки: URL-адреса, API endpoints (REST, GraphQL), веб-формы, параметры запросов (?id=), заголовки, файлы cookie.
- Загружаемые файлы, импорт данных.
- Функции (регистрация, восстановление пароля, поиск, комментарии).

Что именно мы картируем?

Поверхность человеческого фактора:

- Пользователи с разными уровнями привилегий.
- Процессы: восстановление пароля, смена email, вывод средств.
- Уязвимости, связанные с логикой бизнес-процессов.

От тактики к стратегии

Проактивная безопасность: Переход от реагирования на инциденты к их предотвращению.

Приоритизация: Понять, какие компоненты наиболее критичны и уязвимы. Фокус на «коронные активы».

Улучшение коммуникации: Наглядные карты помогают объяснить риски руководству и разработчикам.

Контроль изменений: При добавлении новой функции (например, чат-бота) можно сразу оценить, как расширилась поверхность атаки.

Основой для тестирования: Карта — это план для пентестов и аудитов безопасности.

Как это делается на практике?

Автоматизированное сканирование:

- Сканеры (Nmap, Burp Suite, OWASP ZAP): Для обнаружения сетевых сервисов и endpoint'ов.
- DAST/SAST-инструменты: Поиск известных уязвимостей в коде и работающем приложении.

Как это делается на практике?

Ручной анализ и моделирование угроз:

- Мозговой штурм: Например, по методике STRIDE (Spoofing, Tampering, Repudiation, Info Disclosure, DoS, Elevation of Privilege). Рассмотрение приложения с точки зрения злоумышленника.
- Анализ исходного кода и документации API (Swagger/OpenAPI).

Как это делается на практике?

Визуализация результатов:

- Диаграммы потоков данных (DFD).
- Чек-листы и матрицы рисков.
- Специализированные платформы (например, Maltego для разведки).

Практический пример (Интернет-магазин)

Цель: Показать, как выглядит поверхность атаки в реальном проекте.

Компоненты для анализа:

1) Сеть: shop.com, api.shop.com, admin.shop.com, порт 443.

2) Приложение:

- Публичная часть: /login, /register, /product/<id>, /search?q=, корзина.
- Пользовательская часть: /profile, /orders, /change-password, /upload-avatar.
- Административная часть: /admin/panel, /admin/deleteUser, /admin/exportData.
- API: POST /api/v1/order, GET /api/v1/user/{id}.

3) Человек/Логика: Процесс "Оформить заказ", "Восстановить пароль по email".

Вывод: Каждая из этих точек — потенциальный вектор для атаки (SQL-инъекция в /search, IDOR в /api/v1/user/{id}, CSRF при смене пароля).

Инструментарий

Для разведки и сетевого картографирования: Nmap, Amass, Shodan, OWASP Amass.

Для анализа веб-приложений: Burp Suite (встроенный Target -> Site map), OWASP ZAP, Nikto.

Для визуализации и моделирования: Microsoft Threat Modeling Tool, draw.io (для DFD), Maltego.

Менеджмент и платформы: Jira (с плагинами для безопасности), DefectDojo, ThreadFix.

Не все так просто

Динамичность: Поверхность атаки постоянно меняется (новые функции, микросервисы, облачные контейнеры).

Слепые зоны: Логические уязвимости, авторизация на стороне клиента, сложные бизнес-процессы часто не видны автоматическим сканерам.

«Тень ИТ»: Незарегистрированные API, сторонние сервисы, скрипты, о которых не знает отдел безопасности.

Ложное чувство безопасности: Карта — это инструмент, а не гарантия. Она должна постоянно актуализироваться.

Как внедрить процесс картографирования?

- 1) Интегрируйте в SDLC: Проводите моделирование угроз на этапе проектирования новой функции.
- 2) Регулярность: Обновляйте карту при каждом значительном изменении.
- 3) Автоматизируйте рутину: Используйте CI/CD-пайплайны для автоматического сканирования на наличие новых endpoint'ов или открытых портов.
- 4) Совместная работа: В процесс должны быть вовлечены разработчики, архитекторы, DevOps и специалисты по безопасности (DevSecOps).
- 5) Фокусируйтесь на «коронных активах»: Защищайте в первую очередь данные пользователей, платежные системы, административные интерфейсы.
- 6) Сокращайте поверхность: Отключайте ненужные функции, закрывайте старые поддомены, минимизируйте привилегии.

Ключевые тезисы

- 1) Отображение векторов атаки превращает безопасность из абстрактной концепции в наглядную и управляемую.
- 2) Это не разовое мероприятие, а непрерывный процесс.
- 3) Сочетание автоматических инструментов и ручного анализа (моделирования угроз) дает наилучший результат.
- 4) Главная цель — понимание своей системы лучше, чем это делает потенциальный атакующий, и своевременное сокращение поверхности атаки.